INTERNATIONAL STANDARD 国际标准

ISO/IEC 27701

Second edition 第二版

2025-10

Information security, cybersecurity and privacy protection — Privacy information management systems — Requirements and guidance

信息安全，网络安全和隐私保护 — 隐私信息管理体系 — 要求和指南

本文档源地址：https://bbs.27001.cn/234-1-1.shtml

本文档仅限于个人交流和学习使用，请勿复制，盗用或用于商业用途。

本文档中文是基于 ISO/IEC 27701 的理解和实践进行的翻译，并非使用 AI 或软件进行的翻译。

27001.CN

扫码，关注我的视频号

Sky的安全观

微信扫描二维码，关注我的公众号

ISO 管理体系独家精品课程推荐

ISO/IEC 27001：2022 信息安全管理体系 标准理解与实施	ISO/IEC 20000-1：2018 IT 服务管理体系 标准理解与实施	ISO 22301：2019 业务连续性管理体系 标准理解与实施
限时优惠，原价 8000 元 现在只要 980 元 课程和试看页面链接	限时优惠，原价 2800 元 现在只要 280 元 课程和试看页面链接	限时优惠，原价 2300 元 现在只要 230 元 课程和试看页面链接
ISO/IEC 27701：2019 隐私信息管理体系 标准理解与实施	ISO/IEC 27701：2025 隐私管理体系 标准理解与实施	ISO/IEC 42001：2023 人工智能管理体系 标准理解与实施
限时优惠，原价 3800 元 现在只要 380 元 课程和试看页面链接	近期推出，敬请期待	近期推出，敬请期待
ISO/SAE 21434：2021 道路车辆网络安全工程 标准理解与实施	TISAX 信息安全评估 框架与要求 理解与实施	SOC 2 信息安全评估 框架与要求 理解与实施
近期推出，敬请期待	近期推出，敬请期待	近期推出，敬请期待

目录

INTRODUCTION 引言 5

0.1 GENERAL 概述 5
0.2 COMPATIBILITY WITH OTHER MANAGEMENT SYSTEM STANDARDS 与其他管理体系标准的兼容 7

1 SCOPE 范围 8

2 NORMATIVE REFERENCES 规范性引用文件 9

3 TERMS AND DEFINITIONS 术语和定义 9

4 CONTEXT OF THE ORGANIZATION 组织环境 23

4.1 UNDERSTANDING THE ORGANIZATION AND ITS CONTEXT 理解组织及其环境 23
4.2 UNDERSTANDING THE NEEDS AND EXPECTATIONS OF INTERESTED PARTIES 理解相关方的需求和期望 25
4.3 DETERMINING THE SCOPE OF THE PRIVACY INFORMATION MANAGEMENT SYSTEM 确定隐私信息管理体系的范围 28
4.4 PRIVACY INFORMATION MANAGEMENT SYSTEM 隐私信息管理体系 29

5 LEADERSHIP 领导作用 29

5.1 LEADERSHIP AND COMMITMENT 领导和承诺 29
5.2 PRIVACY POLICY 隐私方针 31
5.3 ROLES, RESPONSIBILITIES AND AUTHORITIES 角色、职责和权限 32

6 PLANNING 策划 33

6.1 ACTIONS TO ADDRESS RISKS AND OPPORTUNITIES 应对风险和机会的措施 33
6.2 PRIVACY OBJECTIVES AND PLANNING TO ACHIEVE THEM 隐私目标及其实现的策划 43
6.3 PLANNING OF CHANGES 变更的策划 44

7 SUPPORT 支持 45

7.1 RESOURCES 资源 45
7.2 COMPETENCE 能力 45
7.3 AWARENESS 意识 46
7.4 COMMUNICATION 沟通 47
7.5 DOCUMENTED INFORMATION 文件化信息 48

8 OPERATION 运行 51

8.1 OPERATIONAL PLANNING AND CONTROL 运行策划和控制 51
8.2 PRIVACY RISK ASSESSMENT 隐私风险评估 52
8.3 PRIVACY RISK TREATMENT 隐私风险处置 53

9 PERFORMANCE EVALUATION 绩效评价 53

9.1 MONITORING, MEASUREMENT, ANALYSIS AND EVALUATION 监视、测量、分析和评价 53
9.2 INTERNAL AUDIT 内部审核 55
9.3 MANAGEMENT REVIEW 管理评审 57

10 IMPROVEMENT 改进 59

10.1 CONTINUAL IMPROVEMENT 持续改进 59
10.2 NONCONFORMITY AND CORRECTIVE ACTION 不符合及纠正措施 59
11 FURTHER INFORMATION ON ANNEXES 有关附录的更多信息 61
ANNEX A 附录 A 63
ANNEX B 附录 B 79
ANNEX C 附录 C 80
ANNEX D 附录 D 81
ANNEX E 附录 E 82
ANNEX F 附录 F 83

Introduction 引言

0.1 General 概述

Almost every organization processes personally identifiable information (PII). Further, the quantity and types of PII processed are increasing, as are the number of situations where an organization needs to cooperate with other organizations regarding the processing of PII. Protection of privacy in the context of the processing of PII is a societal need, as well as the topic of dedicated legal requirements worldwide.

几乎每个组织都会处理个人身份信息（PII）。而且，被处理的个人身份信息（PII）的数量和种类正逐渐增加，组织需要与其他组织就个人身份信息（PII）的处理进行合作的情况也在增加。在个人身份信息（PII）处理的环境下，保护隐私是一种社会需求，也是世界各地专用法律和/或法规的主题。

This document includes mapping to:

本文件包含的内容可以映射到：

—the privacy framework and principles defined in ISO/IEC 29100;

— ISO/IEC 29100 中的隐私框架和原则；

— ISO/IEC 27018;

— ISO/IEC 29151;

—the EU General Data Protection Regulation.

— 欧盟通用数据保护条例（GDPR）。

NOTE These mappings can be interpreted to take into account locallegal requirements.

注：这些映射，可以理解是考虑当地法律要求。

This document can be used by PII controllers (including those that are joint PII controllers) and PII processors (including those using subcontracted PII processors and those processing PII as subcontractors to PII processors).

本文件可以被个人身份信息（PII）控制者（包含共同控制者）和个人身份信息（PII）处理者（包含使用分包个人身份信息（PII）处理者和作为个人身份信息（PII）处理者的分包商处理个人身份信息（PII）的处理者）使用。

By complying with the requirements in this document, an organization can generate evidence of how it handles the processing of PII. Such evidence can be used to facilitate agreements with business partners where the processing of PII is mutually relevant. This can also assist in relationships with other interested parties. The use of this document can provide independent verification of this evidence.

符合本文件要求的组织，应形成如何操纵个人身份信息（PII）的处理的证据。这些证据可以被用来促进与相互关联的

个人身份信息（PII）处理的业务伙伴达成协议。这也有助于与其他相关方的关系。使用本文件，可以对该证据进行独立验证。

0.2 Compatibility with other management system standards 与其他管理体系标准的兼容

This document applies the framework developed by ISO to improve alignment among its management system standards.

本文件应用 ISO 开发的框架，以提升管理体系标准之间的一致性。

This document enables an organization to align or integrate its privacy information management system (PIMS) with the requirements of other management system standards, and in particular with the information security management system specified in ISO/IEC 27001.

本文件使组织能够使其 PIMS 与其他管理体系标准的要求保持一致或使其 PIMS 与其他管理体系标准的要求进行整合，特别是与 ISO/IEC 27001 信息安全管理体系保持一致或进行整合。

1 Scope 范围

This document specifies requirements for establishing, implementing, maintaining and continually improving a privacy information management system (PIMS).

本文件明确了建立、实施、保持和持续改进隐私信息管理体系的要求。

Guidance is also provided to assist in the implementation of the requirements in this document.

也为本文件要求的实施提供了帮助指南。

This document is intended for personally identifiable information (PII) controllers and PII processors holding responsibility and accountability for PII processing.

本文件适用于那些对个人身份信息处理负有责任和职责的个人身份信息控制者和个人身份信息处理者。

This document is applicable to all types and sizes of organizations, including public and private companies, government entities and not-for-profit organizations.

本文件适用于各种类型和各种规模的组织，包括公共和私营公司，政府机构以及非盈利组。

2 Normative references 规范性引用文件

The following documents are referred to in the text in such a way that some or all of their content constitutes requirements of this document. For dated references, only the edition cited applies. For undated references, the latest edition of the referenced document (including any amendments) applies.

下列文件对于本文件的应用是必不可少的。凡是注日期的引用文件，仅注日期的版本适用于本文件。凡是不注日期的引用文件，其最新版本(包括所有的修改单)适用于本文件。

ISO/IEC 29100,Information technology — Security techniques—Privacy framework

ISO/IEC 29100，信息技术 — 安全技术 — 隐私框架

3 Terms and definitions 术语和定义

For the purposes of this document, the terms and definitions given in ISO/IEC29100 and the following apply.

ISO/IEC 29100 界定的术语和定义适用于本文件，以及下列术语和定义适用于本文件。

ISO and IEC maintain terminology databases for use in standardization at the following addresses:

ISO 和 IEC 维护的用于标准化的术语数据库地址如下：

— ISO Online browsing platform: available at https://www.iso.org/obp

— ISO 在线浏览平台：https://www.iso.org/obp

— IEC Electropedia: available at https://www.electropedia.org/p

— IEC 电子开放平台：https://www.electropedia.org/

3.1 organization 组织

person or group of people that has its own functions with responsibilities, authorities and relationships to achieve its objectives (3.6)

拥有自己的责任，权限和关系功能以实现其目标（3.6）的个人或一组人

Note 1 to entry: The concept of organization includes, but is not limited to, sole-trader, company, corporation, firm, enterprise, authority, partnership, charity or institution or part or combination thereof, whether incorporated or not, public or private.

注 1：组织的概念包括但不限于个体经营者，商业实体，公司，商行，企业，行政机构，合伙企业，慈善组织或团体，或其部分或组合，无论是否股份制的、公共或私人。

Note 2 to entry: If the organization is part of a larger entity, the term“organization”refers only to the part of the larger entity

that is within the scope of the privacy information management system(3.23).

注 2：如果组织是较大实体的一部分，则术语“组织”仅指在隐私信息管理体系（3.23）范围内的较大实体的部分。

3.2 interested party 相关方

person or organization (3.1) that can affect, be affected by, or perceive itself to be affected by a decision or activity

能够影响、被影响，或意识到自己受到决策或活动影响的个人或组织（3.1）。

3.3 top management 最高管理层

person or group of people who directs and controls an organization (3.1) at the highest level

在最高层级指导和控制组织的一个人或一组人

Note 1 to entry: Top management has the power to delegate authority and provide resources within the organization.

注 1：最高管理层有权在组织内部授权和提供资源。

Note 2 to entry: If the scope of the management system (3.4) covers only part of an organization, then top management refers to those who direct and control that part of the organization.

注 2：如果管理体系（3.4）仅覆盖组织的部分，此时的最

高管理层是指导和控制组织的那部分的人员。

3.4 management system 管理体系

set of interrelated or interacting elements of an organization (3.1) to establish policies (3.5) and objectives (3.6), as well as processes (3.8) to achieve those objectives

组织（3.1）建立方针（3.5）和目标（3.6），以及过程（3.8）以实现其目标的相互联系或相互影响的一组要素

Note 1 to entry: A management system can address a single discipline or several disciplines.

注 1：管理体系可以应对单个学科或数个学科。

Note 2 to entry: The management system elements include the organization's structure, roles and responsibilities, planning and operation.

注 2：管理体系要素包括组织结构、角色和职责、策划和运行。

3.5 policy 方针

intentions and direction of an organization (3.1) as formally expressed by its top management (3.3)

最高管理层（3.3）正式发布的组织（3.1）意图和方向

3.6 objective 目标

result to be achieved

将要实现的结果

Note 1 to entry: An objective can be strategic, tactical, or operational.

注 1：目标可以是战略性的、战术性的、或经营性的。

Note 2 to entry: Objectives can relate to different disciplines (such as finance, health and safety, and environment). They can be, for example, organization-wide or specific to a project, product or process (3.8).

注 2：目标可以涉及不同的学科（诸如财务、健康和安全、以及环境）。它们可以是，例如组织范围内的，或特定的项目、产品或过程（3.8）。

Note 3 to entry: An objective can be expressed in other ways, e.g. as an intended result, as a purpose, as an operational criterion, as an AI objective or by the use of other words with similar meaning (e.g. aim, goal, or target).

注 3：目标可以通过其他方式表达，例如预期结果、目的、操作标准、AI 目标或使用具有类似含义的其他词语（例如 aim、goal 或 target）。

Note 4 to entry: In the context of privacy information management systems (3.23), privacy objectives are set by the organization (3.1), consistent with the privacy policy (3.5), to achieve specific results.

注 4：在隐私管理体系（3.23）环境下，由组织（3.1）设

定隐私目标，与隐私方针（3.5）保持一致，以实现特定的结果。

3.7 risk 风险

effect of uncertainty

不确定性的影响

Note 1 to entry: An effect is a deviation from the expected — positive or negative.

注 1：影响是预期的偏离 — 正向或负向的。

Note 2 to entry: Uncertainty is the state, even partial, of deficiency of information related to, understanding or knowledge of, an event, its consequence, or likelihood.

注 2：不确定是一种缺乏，甚至部分缺乏，理解或认知事件，其结果或可能性的相关信息的状态。

Note 3 to entry: Risk is often characterized by reference to potential events (as defined in ISO Guide 73) and consequences (as defined in ISO Guide 73), or a combination of these.

注 3：风险通常参考潜在事件（按 ISO Guide 73 定义）和后果（按 ISO Guide 73 定义），以及二者组合为特征。

Note 4 to entry: Risk is often expressed in terms of a combination of the consequences of an event (including changes in circumstances) and the associated likelihood (as defined in ISO Guide 73) of occurrence.

注 4：风险通常从事件的影响（包括环境的变化）和相关

发生的可能性（按 ISO Guide 73 定义）的组合的角度来表述的。

3.8 process 过程

set of interrelated or interacting activities that uses or transforms inputs to deliver a result

使用或转化输入以交付结果的一组相互关联或相互影响的活动

Note 1 to entry: Whether the result of a process is called an output, a product or a service depends on the context of the reference.

注 1：过程的结果是否被称为输出、产品或服务取决于参考的环境。

3.9 competence 能力

ability to apply knowledge and skills to achieve intended results

应用知识和技能实现预期结果的能力

3.10 documented information 文件化信息

information required to be controlled and maintained by an organization (3.1) and the medium on which it is contained

要求组织（3.1）控制和保持的信息，并将其存储在介质上

Note 1 to entry: Documented information can be in any format and media and from any source.

注 1：文件化的信息可以任何格式和介质的，以及任何的

来源。

Note 2 to entry: Documented information can refer to:

注 2：文件化信息可以指：

— the management system (3.4), including related processes (3.8);

— 管理体系（3.4），包含相关过程（3.8）；

— information created in order for the organization to operate (documentation);

— 为组织经营而创建的信息（凭证）；

— evidence of results achieved (records).

— 结果实现的证据（记录）。

3.11 performance 绩效

measurable result

可测量的结果

Note 1 to entry: Performance can relate either to quantitative or qualitative findings.

注 1：绩效可以与定量或定性的发现有关。

Note 2 to entry: Performance can relate to managing activities, processes (3.8), products, services, systems or organizations (3.1).

注 2：绩效可以与活动，过程（3.8），产品，服务，系统或组织（3.1）的管理有关。

3.12 continual improvement 持续改进

recurring activity to enhance performance (3.11)

提高绩效（3.11）的反复活动

3.13 effectiveness 有效性

extent to which planned activities are realized and planned results are achieved

策划活动实现和策划结果完成的程度

3.14 requirement 要求

need or expectation that is stated, generally implied or obligatory

陈述的，普遍默认的或义务性的需求或期望

Note 1 to entry: "Generally implied" means that it is custom or common practice for the organization (3.1) and interested parties (3.2) that the need or expectation under consideration is implied.

注 1：“普遍默认的”意味着对组织（3.1）和相关方（3.2）是习惯性的或是常规做法，所考虑的需求和期望是默认性的。

Note 2 to entry: A specified requirement is one that is stated, e.g. in documented information (3.10).

注 2：明确的要求是陈述的，例如，在文件化信息（3.10）中。

3.15 conformity 符合性

fulfilment of a requirement (3.14)

要求的实现（3.14）

3.16 nonconformity 不符合

non-fulfilment of a requirement (3.14)

要求（3.14）的未实现

3.17 corrective action 纠正措施

action to eliminate the cause(s) of a nonconformity (3.16) and to prevent recurrence

为消除不符合(3.16)原因并防止再次发生所采取的措施。

3.18 audit 审核

systematic and independent process (3.8) for obtaining evidence and evaluating it objectively to determine the extent to which the audit criteria are fulfilled

系统的、独立的、并形成文件化的过程(3.8)，用于获取审核证据并对其进行客观评价，以确定审核准则得到满足的程度

Note 1 to entry: An audit can be an internal audit (first party) or an external audit (second party or third party), and it can be a combined audit (combining two or more disciplines).

注 1：审核可以是内部审核（第一方），或外部审核（第二方或第三方），以及可以是联合审核（联合两个或更多的学科）。

Note 2 to entry: An internal audit is conducted by the organization (3.1) itself, or by an external party on its behalf.

注 2：内部审核由组织（3.1）自身实施，或代表组织的外部方实施。

Note 3 to entry: "Audit evidence" and "audit criteria" are defined in ISO 19011.

注 3：“审核证据”和“审核准则”在 ISO 19011 中被定义。

3.19 measurement 测量

process (3.8) to determine a value

确定值的过程（3.8）

3.20 monitoring 监视

determining the status of a system, a process (3.8) or an activity

确定系统，过程（3.8）或活动的状态

Note 1 to entry: To determine the status, there can be a need to check, supervise or critically observe.

注 1：为确定状态，也许需要检查，监督，或严密观察。

3.21 joint PII controller 共同个人身份信息（PII）控制者

personally identifiable information (PII) controller that determines the purposes and means of the processing of PII jointly with one or more other PII controllers

与一个或多个其他个人身份信息（PII）控制者共同确定个人身份信息（PII）处理目的和方法的个人身份信息（PII）控制者。

3.22 customer 顾客

person or organization (3.1) that can or does receive a product or a service that is intended for or required by this person or organization

可以是接受或实际接受产品或服务的个人或组织（3.1），且该产品或服务是为该个人或组织准备的，或是该个人或组织所要求的。

EXAMPLE Consumer, client, end-user, retailer, receiver of product or service from an internal process (3.8), beneficiary and purchaser.

顾客范例：客户，终端用户，零售商，内部过程（3.8）中的产品或服务的接收者，受益者和购买者。

Note 1 to entry: A customer can be internal or external to the organization.

注 1：顾客既可以是组织内部的，也可以是组织外部的。

Note 2 to entry: A customer can be an organization that has a contract with a PII controller, a PII controller who has a contract with a PII processor or a PII processor that has a contract with a subcontractor for PII processing.

注 2：顾客可以是与个人身份信息控制者签订合同的组织，也可以是与个人身份信息处理者签订合同的个人身份信息控制者，或者是与个人身份信息处理的分包商签订合同的个人身份

信息处理者。

3.23 privacy information management system PIMS 隐私信息管理体系

management system (3.4) which addresses the protection of privacy as potentially affected by the processing of personally identifiable information

应对个人身份信息处理对隐私保护产生的潜在影响的管理体系（3.4）

3.24 information security programme 信息安全计划

set of policies (3.5), objectives (3.6) and processes (3.8) designed to manage risks (3.7) to an organization's (3.1) assets, to ensure confidentiality, integrity and availability of information

为管理组织（3.1）资产风险，确保信息的保密性、完整性和可用性，设计的一系列方针（3.5），目标（3.6）和过程（3.8）

Note 1 to entry: An information security programme can be, for example, an information security management system such as one based on ISO/IEC 27001.

注 1：例如，信息安全计划，可以是基于 ISO/IEC 27001 的信息安全管理体系。

3.25 statement of applicability 适用性声明

documentation of all necessary controls and justification for the inclusion or exclusion of such controls

所有必要控制及纳入或排除控制的理由的文件化信息

4 Context of the organization 组织环境

4.1 Understanding the organization and its context 理解组织及其环境

The organization shall determine external and internal issues that are relevant to its purpose and that affect its ability to achieve the intended result(s) of its privacy information management system.

组织应确定与其意图相关的，且影响其实现隐私信息管理体系预期结果能力的外部和内部事项。

The organization shall determine whether climate change is a relevant issue.

组织应确定气候变化是否是一项相关的事项。

The organization shall determine if it is acting as a PII controller (including as a joint PII controller) or as a PII processor.

组织应确定其是担当个人身份信息控制者（包含共同控制者）角色，还是担当个人身份信息处理者角色。

The organization shall determine external and internal issues that are relevant to its context and that affect its ability to achieve the intended outcome(s) of its PIMS.

组织应确定与其环境相关的，且影响其实现隐私信息管理体系（PIMS）预期结果能力的外部和内部因素。

NOTE 1 External and internal issues can include but are not limited to:

注 1：内外部事项可以包括但不限于以下：

— applicable privacy legislation;

— 适用的隐私法律；

— applicable regulations;

— 适用的法规；

— applicable judicial decisions;

— 适用的司法判决；

— applicable organizational context, governance, policies and procedures;

— 适用的组织环境、治理、策略和程序；

— applicable administrative decisions;

— 适用的管理决策；

— applicable contractual requirements。

— 适用的合同要求。

Where the organization acts in both roles (i.e. a PII controller and a PII processor), separate roles shall be determined, each of which is the subject of a separate set of controls.

当组织扮演双重角色时（例如，个人身份信息控制者和处理者），则应分开确定两个角色，每个角色都对应一组独立的控

制。

NOTE 2 The role of the organization can be different for each instance of the processing of PII, since it depends on who determines the purposes and means of the processing.

注 2：对于不同的个人身份信息处理的实例，组织扮演的角色可以是不同的，因为这取决于谁决定处理的意图和方式。

4.2 Understanding the needs and expectations of interested parties 理解相关方的需求和期望

The organization shall determine:

组织应确定：

— the interested parties that are relevant to the privacy information management system;

— 隐私信息管理体系关联的相关方；

— the relevant requirements of these interested parties;

— 这些相关方的相关要求；

— which of these requirements will be addressed through the privacy information management system.

— 可以通过隐私信息管理体系来应对的要求。

NOTE 1 Relevant interested parties can have requirements related to climate change.

注 1：关联的相关方可能会提出气候变化相关的要求。

The organization shall include among its interested parties those parties having interests or responsibilities associated with the processing of PII, including the PII principals.

组织应将与个人身份信息处理相关联的利益或责任方（包括个人身份信息主体）纳入其相关方之中。

NOTE 2 Other interested parties can include customers, supervisory authorities, other PII controllers, PII processors and their subcontractors.

注 2：其他相关方可以包括顾客，监管机构，其他的个人身份信息控制者，个人身份信息处理者以及其分包商。

Depending on the role of the organization, "customer" can be understood as either:

根据组织的角色，“顾客”也可以被理解为：

a) an organization who has a contract with a PII controller (e.g. the customer of the PII controller);

a）与个人身份信息控制者签订合同的组织（例如，个人身份信息控制者的顾客）；

NOTE3 This can be the case of an organization which is a joint PII controller.

注 3：这可能是组织作为共同个人身份信息控制者这种情形。

b) a PII controller who has a contract with a PII processor

(e.g. the customer of the PII processor); or

b）与个人身份信息处理者签订合同的个人身份信息控制者（例如，个人身份信息处理者的顾客）；

c) a PII processor who has a contract with a subcontractor for PII processing (e.g. the customer of the subcontracted PII processor).

c）与个人身份信息处理分包商签订合同的个人身份信处理者（例如，个人身份信息分包处理者的顾客）。

NOTE 4 An individual person whose PII is processed in a business association (for example in a consumer, employee, vendor, visitor relationship) is referred to as a "PII principal" in this document.

注 4：在本文件中，当个人的个人身份信息在商业机构中被处理（例如在顾客、雇员、供应商、访客关系中）时，该个人被称为“个人身份信息主体”。

NOTE 5 Requirements relevant to the processing of PII can be determined by legal and regulatory requirements, by contractual obligations and by self-imposed organizational objectives. The privacy principles set out in ISO/IEC 29100 provide guidance concerning the processing of PII.

注 5：个人身份信息处理过程中的相关要求，可以由法规和监管要求，合同义务，以及组织自身目标确定。

NOTE 6 To demonstrate conformity with the organization's obligations, some interested parties can expect that the organization is in conformity with specific standards, such as the management system specified in this document or any relevant set of specifications. These parties can call for independently audited conformity to these standards.

注 6：为证明符合组织承担的义务，相关方可能期望组织满足特定的标准要求，例如本文件中的管理体系要求，或者任何相关的系列规范。

4.3 Determining the scope of the privacy information management system 确定隐私信息管理体系的范围

The organization shall determine the boundaries and applicability of the privacy information management system to establish its scope.

组织应确定隐私信息管理体系的边界及其适用性，以建立其范围。

When determining this scope, the organization shall consider:

在确定范围时，组织应考虑：

— the external and internal issues referred to in 4.1;

— 4.1 中提到的外部和内部事项；

— the requirements referred to in 4.2.

— 4.2 中提到的要求。

The scope shall be available as documented information.

该范围应形成文件化信息并可用。

When determining the scope of the PIMS, the organization shall include the processing of PII.

在确定隐私信息管理体系的范围时，组织应将个人身份信息的处理纳入其中。

4.4 Privacy information management system 隐私信息管理体系

The organization shall establish, implement, maintain and continually improve a privacy information management system, including the processes needed and their interactions, in accordance with the requirements of this document.

组织应按照本文件的要求，建立、实施、保持和持续改进隐私信息管理体系，包括所需的过程及其相互作用。

5 Leadership 领导作用

5.1 Leadership and commitment 领导和承诺

Top management shall demonstrate leadership and

commitment with respect to the privacy information management system by:

最高管理层应通过以下活动，以证实对隐私信息管理体系的领导和承诺：

— ensuring that the privacy policy (see 5.2) and privacy objectives (see 6.2) are established and are compatible with the strategic direction of the organization;

— 确保建立了隐私方针（见 5.2）和隐私目标（见 6.2），并与组织战略方向保持一致；

— ensuring the integration of the privacy information management system requirements into the organization's business processes;

— 确保将隐私信息管理体系要求整合到组织业务过程中；

— ensuring that the resources needed for the privacy information management system are available;

— 确保隐私信息管理体系所需资源可用；

— communicating the importance of effective privacy information management and of conforming to the privacy information management system requirements;

— 沟通有效的隐私信息管理及符合隐私信息管理体系要求的重要性；

— ensuring that the privacy information management

system achieves its intended result(s);

— 确保隐私信息管理体系达到预期结果；

— directing and supporting persons to contribute to the effectiveness of the privacy information management system;

— 指导并支持相关人员为隐私信息管理体系的有效性做出贡献；

— promoting continual improvement;

— 促进持续改进；

— supporting other relevant roles to demonstrate their leadership as it applies to their areas of responsibility.

— 支持其他相关管理角色，以证实他们在适用责任领域的领导能力。

NOTE Reference to “business” in this document can be interpreted broadly to mean those activities that are core to the purposes of the organization's existence.

注：本文件使用的“业务”一词可广义地理解为涉及组织存在目的的核心活动。

5.2 Privacy policy 隐私方针

Top management shall establish a privacy policy that:

最高管理层应建立隐私方针，该方针应：

a) is appropriate to the purpose of the organization;

a）与组织意图相适宜；

b) provides a framework for setting privacy objectives;

b）为隐私目标的设定提供框架；

c) includes a commitment to meet applicable requirements;

c）包含对满足适用要求的承诺；

d) includes a commitment to continual improvement of the privacy information management system.

d）包括对持续改进隐私信息管理体系的承诺。

The privacy policy shall:

隐私方针应：

— be available as documented information;

— 形成文件化信息并可用；

— be communicated within the organization;

— 在组织内得到沟通；

— be available to interested parties, as appropriate.

— 适当时，对相关方可用。

5.3 Roles, responsibilities and authorities 角色、职责和权限

Top management shall ensure that the responsibilities and authorities for relevant roles are assigned and communicated within the organization.

最高管理层应确保相关角色的责任和权限在组织内得到分配和沟通。

Top management shall assign the responsibility and authority for:

最高管理层应分配责任和权限，以：

a) ensuring that the privacy information management system conforms to the requirements of this document;

a）确保隐私信息管理体系符合本文件的要求；

b) reporting on the performance of the privacy information management system to top management.

b）向最高管理层报告隐私信息管理体系绩效。

6 Planning 策划

6.1 Actions to address risks and opportunities 应对风险和机会的措施

6.1.1 General 总则

When planning for the privacy information management system, the organization shall consider the issues referred to in 4.1 and the requirements referred to in 4.2 and determine the risks and opportunities that need to be addressed to:

在策划隐私信息管理体系时，组织应考虑 4.1 中提到的事

项和 4.2 中提到的要求，并确定需要应对的风险和机会，以：

— give assurance that the privacy information management system can achieve its intended result(s);

— 确保隐私信息管理体系可达到预期结果；

— prevent, or reduce, undesired effects;

— 预防或减少不良影响；

— achieve continual improvement.

— 达到持续改进。

The organization shall plan:

组织应策划：

a) actions to address these risks and opportunities;

a）应对这些风险和机会的措施；

b) how to

b）如何

— integrate and implement the actions into its privacy information management system processes;

— 将这些措施整合到隐私信息管理体系过程中，并予以实现；

— evaluate the effectiveness of these actions.

— 评价这些措施的有效性。

6.1.2 Privacy risk assessment 隐私风险评估

The organization shall define and apply a privacy risk assessment process that:

组织应定义并应用隐私风险评估过程，以：

a) establishes and maintains privacy risk criteria that include:

a）建立并维护隐私风险准则，包括：

1) the risk acceptance criteria; and

1）风险接受准则；

2) criteria for performing privacy risk assessments;

2）隐私风险评估实施准则；

b) ensures that repeated privacy risk assessments produce consistent, valid and comparable results;

b）确保反复的隐私风险评估产生一致的、有效的和可比较的结果。

c) identifies the privacy risks:

c）识别隐私风险：

1) associated with the protection of privacy and information security risks within the scope of the privacy information management system; and

1）隐私信息管理体系覆盖范围内相关的隐私保护和信息安全风险；

2) that identify the risk owners;

2）识别风险责任人；

d) analyses the privacy risks that:

d）分析隐私风险：

1) assess the potential consequences for both the organization and PII principals that would result if the risks identified in c) 1) were to materialize;

1）评估 c) 1)中所识别的风险发生后，可能对组织和个人身份信息主体产生的潜在后果；

2) assess the realistic likelihood of the occurrence of the risks identified in c) 1); and

2）评估 c) 1)中所识别的风险实际发生的可能性；

3) determine the levels of risk;

3）确定风险级别；

e) evaluates the privacy risks that:

e）评价隐私风险：

1) compare the results of risk analysis with the risk criteria established in a); and

1）将风险分析结果与 a)中建立的风险准则进行比较；

2) prioritize the analysed risks for risk treatment.

2）为风险处置，排序已分析风险的优先级。

The organization shall retain documented information

about the privacy risk assessment process.

组织应保留有关隐私风险评估过程的文件化信息。

NOTE For further information on the privacy risk assessment process, see ISO/IEC 27557.

注：更多有关隐私风险评估过程的信息，可以参见 ISO/IEC 27557。

6.1.3 Privacy risk treatment 隐私风险处置

The organization shall define and apply a privacy risk treatment process to treat risks related to the processing of PII, including risks to PII principals, and including the security of PII, by:

为处置个人身份信息处理过程中的相关风险，包括对个人身份信息主体产生的风险和个人身份信息的安全风险，组织应定义和应用隐私风险处置过程，以：

a) selecting appropriate privacy risk treatment options, taking account of the risk assessment results;

a）在考虑风险评估结果的基础上，选择适合的隐私风险处置选项；

b) determining all controls that are necessary to implement the privacy risk treatment option(s) chosen;

b）确定实现已选的隐私风险处置选项所必需的所有控制；

NOTE 1 Organizations can design controls as required or identify them from any source.

注 1：当需要时，组织可设计控制，或识别来自任何来源的控制。

c) identifying and documenting the information security programme implemented by the organization, including the appropriate security controls;

c）识别组织实施的信息安全计划，包括适用的安全控制，并对其文件化；

The information security programme at a minimum should address the following:

信息安全计划应足够应对：

— information security risk management;

— 信息安全风险管理；

— policies for information security;

— 信息安全策略；

— organization of information security;

— 信息安全组织；

— human resources security;

— 人力资源安全；

— asset management;

— 资产管理；

— access control;

— 访问控制；

— operations security;

— 运行安全；

— network security management;

— 网络安全管理；

— development security;

— 开发安全；

— supplier management;

— 供应链管理；

— incident management;

— 事件管理；

— information security continuity;

— 信息安全连续性；

— information security reviews;

— 信息安全评审；

— cryptography; and

— 密码学；

— physical and environmental security.

— 物理和环境安全。

NOTE 2 ISO/IEC 27002 provides a list of possible information security controls. If the information security

programme is based on ISO/IEC 27001, ISO/IEC 27002 can be consulted to ensure that no necessary information security controls are overlooked.

注 2：ISO/IEC 27002 提供了可能需要的信息安全控制列表。如果信息安全计划是基于 ISO/IEC 27001，那么可以参考 ISO/IEC 27002，以确保必要的信息安全控制没有被忽略。

d) comparing the controls determined in b) and c) above with those in Annex A and verifying that no necessary controls have been omitted;

d）将以上 b)和 c)确定的控制与附录 A 中的控制进行比较，并验证没有忽略必要的控制；

NOTE 3 Annex A contains a list of possible privacy controls. Annex A can be consulted to ensure that no necessary privacy controls are overlooked.

注 3：附录 A 包含了可能所需的隐私控制列表。可以参考附录 A，以确保必要的隐私控制没有被忽略。

NOTE 4 The privacy controls listed in Annex A are not exhaustive and additional privacy controls can be included if needed.

注 4：附录 A 所列的隐私控制并不是完备的，如果有需要，可以包含额外的隐私控制。

NOTE 5 Organizations can address information security and

privacy in an integrated manner when considering the security of PII processing, combining information security and privacy risk assessments for example, or as separate entities with overlapping areas.

注 5：在考虑个人身份信息处理安全时，组织可以以整合的方式应对信息安全和隐私保护（例如，整合信息安全和隐私风险评估），也可以以独立且重叠的方式应对信息安全和隐私保护。

e) producing a statement of applicability that includes:

e）制定一个适用性声明（SOA），其包含：

— the necessary controls [see b],c]and d]];

— 必要的控制（见 b)，c)和 d))；

— justification for their inclusion;

— 其选择的合理说明；

— whether the necessary controls are implemented or not; and

— 无论该必要的控制是否已实现；

— the justification for excluding any of the controls from Annex A.

— 及对附录 A 控制删减的合理性说明。

It is not necessary to include all controls listed in Annex A. For example, controls can be excluded if they are not deemed

necessary by the risk assessment or are not covered by (or are subject to exceptions under) the applicable legal requirements, including those applicable to the PII principal.

没有必要选择附录 A 中的所有控制。例如，风险评估认为没有必要时，或者不在适用法规要求之内时，或者属于适用法规要求例外情形时，这些适用法规要求包括对个人身份信息主体适用法规要求，那么相关控制可以排除。

f) formulating a privacy risk treatment plan;

f）制定正式的隐私风险处置计划;

g) obtaining the privacy risk owners' approval of the privacy risk treatment plan and acceptance of the residual privacy risks; and

g）获得隐私风险责任人对隐私风险处置计划以及对隐私残余风险的接受的批准。

h) considering the guidance in Annex B for the implementation of controls determined in b) and c).

h）在 b) 和 c)确认的控制，可以考虑参照附录 B 中的指南进行实施。

The organization shall retain documented information about the privacy risk treatment process.

组织应保留有关隐私风险处置过程的文件化信息。

6.2 Privacy objectives and planning to achieve them 隐私目标及其实现的策划

The organization shall establish privacy objectives at relevant functions and levels.

组织应在相关职能和层级上建立隐私目标。

The privacy objectives shall:

隐私目标应：

a) be consistent with the privacy policy (see 5.2);

a）与隐私方针（见 5.2）一致；

b) be measurable (if practicable);

b）可测量(如可行)；

c) take into account applicable requirements;

c）考虑适用的要；

d) be monitored;

d）予以监视；

e) be communicated;

e）予以沟通；

f) be updated as appropriate;

f）适时更新；

g) be available as documented information.

g）形成文件化信息并可用。

When planning how to achieve its privacy objectives, the organization shall determine:

在策划如何达到隐私目标时，组织应确定：

— what will be done;

— 要做什么；

— what resources will be required;

— 需要什么资源；

— who will be responsible;

— 由谁负责；

— when it will be completed;

— 什么时候完成；

— how the results will be evaluated.

— 如何评价结果。

6.3 Planning of changes 变更的策划

When the organization determines the need for changes to the privacy information management system, the changes shall be carried out in a planned manner.

当组织确定需要对隐私信息管理体系进行变更时，变更应按所策划的方式实施。

7 Support 支持

7.1 Resources 资源

The organization shall determine and provide the resources needed for the establishment, implementation, maintenance and continual improvement of the privacy information management system.

组织应确定并提供建立、实现、维护和持续改进隐私管理体系所需的资源。

7.2 Competence 能力

The organization shall:

组织应:

— determine the necessary competence of person(s) doing work under its control that affects its privacy information management performance;

— 确定在组织控制下从事会影响组织隐私信息管理绩效的工作人员的必要能力;

— ensure that these persons are competent on the basis of appropriate education, training, or experience;

— 确保上述人员在适当的教育、培训或经验的基础上能够胜任其工作;

— where applicable, take actions to acquire the necessary competence, and evaluate the effectiveness of the actions taken.

— 适用时，采取措施以获得必要的能力，并评估所采取措施的有效性；

Appropriate documented information shall be available as evidence of competence.

保留适当的文件化信息作为能力的证据。

NOTE Applicable actions can include, for example: the provision of training to, the mentoring of, or the reassignment of currently employed persons; or the hiring or contracting of competent persons.

注：适用的措施可以包括，例如针对现有雇员提供培训、指导或重新分配；或者雇佣或签约有能力的人员。

7.3 Awareness 意识

Persons doing work under the organization's control shall be aware of:

在组织控制下工作的人员应知晓：

— the privacy policy (see 5.2);

— 隐私方针（见 5.2）；

— their contribution to the effectiveness of the privacy information management system, including the benefits of

improved privacy performance;

— 其对隐私信息管理体系有效性的贡献，包括改进隐私绩效带来的益处;

— the implications of not conforming with the privacy information management system requirements.

— 不符合隐私信息管理体系要求带来的影响。

7.4 Communication 沟通

The organization shall determine the internal and external communications relevant to the privacy information management system including:

组织应确定与隐私信息管理体系相关的内部和外部的沟通需求，包括:

— on what it will communicate;

— 沟通什么;

— when to communicate;

— 何时沟通;

— with whom to communicate;

— 与谁沟通;

— how to communicate.

— 如何沟通。

7.5 Documented information 文件化信息

7.5.1 General 总则

The organization's privacy information management system shall include:

组织的隐私信息管理体系应包括:

a) documented information required by this document;

a）本文件要求的文件化信息;

b) documented information determined by the organization as being necessary for the effectiveness of the privacy information management system.

b）为隐私信息管理体系的有效性，组织所确定的必要的文件化信息。

NOTE The extent of documented information for a privacy information management system can differ from one organization to another due to:

注：不同组织有关隐私信息管理体系文件化信息的详略程度可以是不同的，这是由于:

— the size of organization and its type of activities, processes, products and services;

— 组织的规模及其活动、过程、产品和服务的类型;

— the complexity of processes and their interactions;

— 过程及其相互作用的复杂性;

— the competence of persons.

— 人员能力。

7.5.2 Creating and updating documented information 创建和更新文件化信息

When creating and updating documented information, the organization shall ensure appropriate:

创建和更新文件化信息时，组织应确保适当的:

— identification and description (e.g. a title, date, author, or reference number);

— 标识和描述(例如标题、日期、作者或引用编号);

— format (e.g. language, software version, graphics) and media(e.g. paper, electronic);

— 格式(例如语言、软件版本、图表)和介质(例如纸质的、电子的);

— review and approval for suitability and adequacy.

— 对适宜性和充分性的评审和批准。

7.5.3 Control of documented information 文件化信息的控制

Documented information required by the privacy

information management system and by this document shall be controlled to ensure:

隐私信息管理体系及本文件所要求的文件化信息应得到控制，以确保：

a) it is available and suitable for use, where and when it is needed;

a）在需要的场合和时机，均可获得并适用；

b) it is adequately protected (e.g. from loss of confidentiality, improper use, or loss of integrity).

b）得到充分的保护(如避免保密性损失、不恰当使用、完整性损失等)。

For the control of documented information, the organization shall address the following activities, as applicable:

为控制文件化信息，适用时，组织应进行以下活动：

— distribution, access, retrieval and use;

— 分发，访问，检索和使用；

— storage and preservation, including preservation of legibility;

— 存储和保护，包括保持可读性；

— control of changes (e.g. version control);

— 控制变更(例如，版本控制)；

— retention and disposition.

— 保留和处置。

Documented information of external origin determined by the organization to be necessary for the planning and operation of the privacy information management system shall be identified as appropriate, and controlled.

对于组织确定的策划和运行隐私信息管理体系所必需的来自外部的文件化信息，组织应进行适当识别，并予以控制。

NOTE Access can imply a decision regarding the permission to view the documented information only, or the permission and authority to view and change the documented information.

注：对文件化信息的“访问”可能意味着仅允许查阅，或者意味着允许查阅并授权修改等其他权限。

8 Operation 运行

8.1 Operational planning and control 运行策划和控制

The organization shall plan, implement and control the processes needed to meet requirements, and to implement the actions determined in Clause 6, by:

为了满足要求以及实施条款 6 中确定的措施，组织应通过以下措施对所需的过程进行策划、实施和控制：

— establishing criteria for the processes;

— 建立过程准则;

— implementing control of the processes in accordance with the criteria.

— 按照准则实施过程控制;

Documented information shall be available to the extent necessary to have confidence that the processes have been carried out as planned.

文件化信息应在必要的程度上予以保持，以确信这些过程按策划得到执行。

The organization shall control planned changes and review the consequences of unintended changes, taking action to mitigate any adverse effects, as necessary.

组织应控制策划的变更，评审非预期变更的后果，必要时，采取措施减轻不利影响。

The organization shall ensure that externally provided processes, products or services that are relevant to the privacy information management system are controlled.

组织应确保外部提供的，且与隐私信息管理体系有关的过程、产品或服务受到控制。

8.2 Privacy risk assessment 隐私风险评估

The organization shall perform privacy risk assessments at

planned intervals or when significant changes are proposed or occur, taking account of the criteria established in 6.1.2 a).

组织应考虑 6.1.2 a)所建立的准则，按策划的时间间隔，或当重大变更提出或发生时，执行隐私风险评估。

The organization shall retain documented information of the results of the privacy risk assessments.

组织应保留隐私风险评估结果的文件化信息。

8.3 Privacy risk treatment 隐私风险处置

The organization shall implement the privacy risk treatment plan.

组织应实施隐私风险处置计划。

The organization shall retain documented information of the results of the privacy risk treatment.

组织应保留隐私风险处置结果的文件化信息。

9 Performance evaluation 绩效评价

9.1 Monitoring, measurement, analysis and evaluation 监视、测量、分析和评价

The organization shall determine:

组织应确定：

— what needs to be monitored and measured;

— 需要被监视和测量的内容

— the methods for monitoring, measurement, analysis and evaluation, as applicable, to ensure valid results;

— 适用的监视、测量、分析和评价的方法，以确保得到有效的结果；

— when the monitoring and measuring shall be performed;

— 何时应执行监视和测量；

— when the results from monitoring and measurement shall be analysed and evaluated.

— 何时应分析和评价监视和测量的结果；

Documented information shall be available as evidence of the results.

适当的文件化信息应予以保留，以作为结果的证据。

The organization shall evaluate the privacy performance and the effectiveness of the privacy information management system.

组织应评价隐私绩效以及隐私信息管理体系的有效性。

9.2 Internal audit 内部审核

9.2.1 General 总则

The organization shall conduct internal audits at planned intervals to provide information on whether the privacy information management system:

组织应按照策划的时间间隔进行内部审核，以提供隐私信息管理体系有关的下列信息：

a) conforms to:

a) 是否符合：

— the organization's own requirements for its privacy information management system;

— 组织自身对隐私信息管理体系的要求；

— the requirements of this document;

— 本文件要求；

b) is effectively implemented and maintained.

b) 是否得到有效的实施和保持。

9.2.2 Internal audit programme 内部审核方案

The organization shall plan, establish, implement and maintain (an) audit programme(s), including the frequency, methods, responsibilities, planning requirements and reporting.

组织应策划、建立、实施和保持一项或多项审核方案，其中包括频率、方法、责任、策划要求和报告。

When establishing the internal audit programme(s), the organization shall consider the importance of the processes concerned and the results of previous audits.

建立内部审核方案时，组织应考虑到有关过程的重要性和以前审核的结果。

The organization shall:

组织应：

a) define the audit objectives, criteria and scope for each audit;

a）定义每次审核的审核目标，审核准则和审核范围；

b) select auditors and conduct audits to ensure objectivity and the impartiality of the audit process;

b）选择审核员并实施审核，以确保审核过程的客观性和公正性；

c) ensure that the results of audits are reported to relevant managers.

c）确保将审核结果报告至相关管理层。

Documented information shall be available as evidence of the implementation of the audit programme(s) and the audit results.

文件化信息应予以保留，以作为审核方案实施和审核结果的证据。

9.3 Management review 管理评审

9.3.1 General 总则

Top management shall review the organization's privacy information management system, at planned intervals, to ensure its continuing suitability, adequacy and effectiveness.

最高管理层应按照策划的时间间隔对组织的隐私信息管理体系进行评审，以确保其持续的适宜性、充分性和有效性。

9.3.2 Management review inputs 管理评审输入

The management review shall include:

管理评审应考虑：

a) the status of actions from previous management reviews;

a) 以往管理评审所采取措施的情况；

b) changes in external and internal issues that are relevant to the privacy information management system;

b）与隐私信息管理体系相关的内外部事项的变化；

c) changes in needs and expectations of interested parties that are relevant to the privacy information management system;

c）与隐私信息管理体系相关的相关方需求和期望的变化；

d) information on the privacy information management system performance, including trends in:

d）有关隐私信息管理体系绩效的信息，包括以下方面的趋势:

— nonconformities and corrective actions;

— 不符合和纠正措施;

— monitoring and measurement results;

— 监视和测量结果;

— audit results;

— 审核结果;

e) opportunities for continual improvement.

e）持续改进的机会。

9.3.3 Management review results 管理评审输出

The results of the management review shall include decisions related to continual improvement opportunities and any need for changes to the privacy information management system.

管理评审的结果应包括与持续改进机会相关的决定以及变更隐私信息管理体系的任何需求。

Documented information shall be available as evidence of the results of management reviews.

文件化信息应予以保留，以作为管理评审结果的证据。

10 Improvement 改进

10.1 Continual improvement 持续改进

The organization shall continually improve the suitability, adequacy and effectiveness of the privacy information management system.

组织应持续改进隐私信息管理体系的适宜性、充分性和有效性。

10.2 Nonconformity and corrective action 不符合及纠正措施

When a nonconformity occurs, the organization shall:

当发生不符合时，组织应：

a) react to the nonconformity, and as applicable:

a）对不符合做出反应,适用时：

— take action to control and correct it;

— 采取措施，以控制并予以纠正；

— deal with the consequences;

— 处置后果；

b) evaluate the need for action to eliminate the cause(s) of

the nonconformity, in order that it does not recur or occur elsewhere, by:

b）通过以下活动，评价采取消除不符合原因的措施的需求，以防止不符合再发生，或在其他地方发生：

— reviewing the nonconformity;

— 评审不符合；

— determining the causes of the nonconformity;

— 确定不符合的原因；

— determining if similar nonconformities exist, or can potentially occur;

— 确定类似的不符合是否存在，或可能发生；

c) implement any action needed;

c）实施任何需要的措施；

d) review the effectiveness of any corrective action taken;

d）评审任何所采取的纠正措施的有效性；

e) make changes to the privacy information management system, if necessary.

e）必要时，对隐私信息管理体系进行变更。

Corrective actions shall be appropriate to the effects of the nonconformities encountered.

纠正措施应与所遇到的不符合的影响相适合。

Documented information shall be available as evidence of:

文件化信息应予以保留，以作为以下方面的证据：

— the nature of the nonconformities and any subsequent actions taken;

— 不符合的性质及所采取的任何后续措施；

— the results of any corrective action.

— 任何纠正措施的结果。

11 Further information on annexes 有关附录的更多信息

Annex C contains a mapping between the provisions of this document and the privacy principles from ISO/IEC 29100.

附录 C 包含了本文件条款和 ISO/IEC 29100 隐私原则之间的映射。

Annex D contains a mapping of the controls in this document to the European Union General Data Protection Regulation.

附录 D 包含了本文件控制和欧盟通用数据保护条例之间的映射。

Annex E contains a mapping of the provisions of this document and the provisions from ISO/IEC 27018 and ISO/IEC 29151.

附录 E 包含了本文件条款与 ISO/IEC 27018 和 ISO/IEC 29151 条款之间的映射。

Annex F shows the correspondence between the controls in this edition of ISO/IEC 27701 and the previous edition (ISO/IEC 27701:2019).

附录 F 展示了当前版本 ISO/IEC 27701 控制和前一版本(ISO/IEC 27701:2019)控制之间的联系。

Annex A 附录 A

PIMS reference control objectives and controls for PII controllers and PII processors

个人身份信息控制者和个人身份信息处理者隐私信息管理体系参考控制目标和控制项

This annex is intended to be used by organizations acting as PII controllers or PII processors, or both. It is not necessary to include all control objectives and controls listed in this annex in the PIMS implementation.

本附录是供充当个人身份信息控制者，或个人身份信息处理者，或充当前面两个角色的组织使用的。在实施隐私信息管理体系时，没有必要选择本附录全部的控制目标和控制项。

A justification for excluding any control objectives shall be included in the statement of applicability [see6.1.3 e]. Justification for exclusion can include where the controls are not deemed necessary by the risk assessment, and where they are not required by (or are subject to exceptions under) the applicable legal requirements.

应在适用性声明（见 6.1.3 e）中阐明任何的控制目标被排除的合理理由。排除的合理理由可能包括：在风险评估中认为这些控制措施并非必要；或者这些控制措施并非由适用的法律

要求所规定，或者在这些法律要求下存在例外情况。

Table A.1 applies to PII controllers, Table A.2 applies to PII processors and Table A.3 relates to information security controls for both PII controllers and PII processors.

表 A.1 适用于个人身份信息控制者，表 A.2 适用于个人身份信息处理者，以及表 A.3 信息安全相关的控制适用于个人身份信息控制者和个人身份信息处理者。

NOTE The references under“Control reference” in Tables A.1, A.2 and A.3 refer to the equivalent clause numbers in Annex B (e.g. guidance for control A.1.2.2 can be found in B.1.2.2).

注：表 A.1、A.2 和 A.3 中“控制索引”部分所列出的参考索引均指向附录 B 中的相应条款编号（例如，关于控制 A.1.2.2 的指南信息可在 B.1.2.2 中找到）。

Table A.1—Control objectives and controls for PII controllers

表 A.1 个人身份信息控制者控制目标和控制项

Conditions for collection and processing 收集和处理条件 **Objective 目标：** To demonstrate that processing is lawful, with legal basis as per applicable jurisdictions, with clearly defined and legitimate purposes. 为确定处理是合法的，且符合各个适用的司法管辖区的法律依据，以及有清晰的定义和正当目的。		
Control Reference 控制索引	**Control title 控制标题**	**Control 控制**
A.1.2.2	Identify and document purpose 表明和文件化目的	The organization shall identify and document the specific purposes for which the PII will be processed.. 组织应表明和文件化个人身份信息（PII）被处理的明确目的。
A.1.2.3	Identify lawful basis	The organization shall determine, document

	识别合法依据	and be able to demonstrate compliance with the relevant lawful basis for the processing of PII for the identified purposes. 组织应确定，文件化和能够证明按照表明目的处理个人身份信息（PII）符合相关法律的依据
A.1.2.4	Determine when and how consent is to be obtained 确定何时和如何获得许可	The organization shall determine and document a process by which it can demonstrate if, when and how consent for the processing of PII was obtained from PII principals. 组织应确定和文件化流程，以便组织通过此流程可以证明个人身份信息（PII）的处理是否，何时以及如何获得个人身份信息（PII）主体的许可。
A.1.2.5	Obtain and record consent 获取和记录许可	The organization shall obtain and record consent from PII principals. 组织应获得和记录个人身份信息（PII）主体的许可。
A.1.2.6	Privacy impact assessment 隐私影响评价	The organization shall assess the need for, and implement where appropriate, a privacy impact assessment whenever new processing of PII or changes to existing processing of PII is planned. 每当计划对个人身份信息（PII）进行新的处理或对现有个人身份信息（PII）处理进行更改时，组织应评估隐私影响评价的需求，并在适当的情况下实施隐私影响评价。
A.1.2.7	Contracts with PII processors 与个人身份信息（PII）处理者的合同	The organization shall have a written contract with any PII processor that it uses, and shall ensure that their contracts with PII processors address the implementation of the appropriate controls in Annex A (see Table A.2). 组织应与其使用的所有个人身份信息（PII）处理者签订书面的合同，并应确保其与个人身份信息（PII）处理者签订的合同涵盖附录A（见表 A.2）中适用的控制项的实施的内容。
A.1.2.8	Joint PII controller 共同个人身份信息（PII）控制者	The organization shall determine respective roles and responsibilities for the processing of PII (including PII protection and security requirements) with any joint PII controller. 组织应与所有共同个人身份信息（PII）控制者确定各自的个人身份信息（PII）处理的角色和责任（包含个人身份信息（PII）保护和安全要求）。
A.1.2.9	Records related to processing PII 处理个人身份信息（PII）有关的记录	The organization shall determine and securely maintain the necessary records in support of its obligations for the processing of PII. 组织应确定和安全地保持必要的记录，以便支持履行其个人身份信息（PII）处理活动中的义务。
Obligations to PII principals 对个人身份信息（PII）主体的义务		

Objective 目标： objective: To ensure that PII principals are provided with appropriate information about the processing of their PII, and to meet any other applicable obligations to PII principals related to the processing of their PII. 为确保将个人身份信息（PII）主体的个人身份信息（PII）处理相关的适当信息提供给个人身份信息（PII）主体，以及为满足对个人身份信息（PII）主体的个人身份信息（PII）处理相关的个人身份信息（PII）主体的任何其他适当义务。		
A.1.3.2	Determining and fulfilling obligations to PII principals 确定和履行对个人身份信息（PII）主体的义务	The organization shall determine and document its legal, regulatory and business obligations to PII principals related to the processing of their PII and provide the means to meet these obligations. 组织应确定和文件化其对个人身份信息（PII）主体的个人身份信息（PII）处理相关的个人身份信息（PII）主体的法律，法规和商业义务，并提供满足这些义务的方法。
A.1.3.3	Determining information for PII principals 确定提供给个人身份信息（PII）主体的信息	The organization shall determine and document the information to be provided to PII principals regarding the processing of their PII and the timing of such a provision. 组织应确定和文件化向个人身份信息（PII）主体的个人身份信息（PII）处理相关的个人身份信息（PII）主体提供的信息，以及提供的时机。
A.1.3.4	Providing information to PII principals 向个人身份信息（PII）主体提供信息	The organization shall provide PII principals with clear and easily accessible information identifying the PII controller and describing the processing of their PII. 组织应向个人身份（PII）主体提供清晰和便利的信息，以说明个人身份信息（PII）控制者的身份，以及描述个人身份（PII）主体的个人身份信息（PII）的处理。
A.1.3.5	Providing mechanism to modify or withdraw consent 提供修改或撤回许可的机制	The organization shall provide a mechanism for PII principals to modify or withdraw their consent. 组织应向个人身份信息（PII）主体提供修改或撤回其许可的机制。
A.1.3.6	Providing mechanism to object to PII processing 提供反对个人身份信息（PII）处理的机制	The organization shall provide a mechanism for PII principals to object to the processing of their PII. 组织应向个人身份信息（PII）主体提供反对其个人身份信息（PII）被处理的机制。
A.1.3.7	Access, correction or erasure 访问，改正或清除	The organization shall implement policies, procedures or mechanisms to meet its obligations to PII principals to access, correct or erase their PII. 组织应实施策略，规程或机制，以履行其对个人身份信息（PII）主体的访问，改正或清除其个人身份信息（PII）的义务。
A.1.3.8	PII controllers' obligations to inform third parties 个人身份信息（PII）控制者通知第三方的义务	The organization shall inform third parties with whom PII has been shared of any modification, withdrawal or objections pertaining to the shared PII, and implement appropriate policies, procedures or mechanisms to do so. 组织应实施适宜的策略，规程或机制，将共

		享的个人身份信息（PII）相关的所有修改，撤回或反对告知给个人身份信息（PII）已经被共享的第三方。
A.1.3.9	Providing copy of PII processed 提供处理的个人身份信息（PII）的副本	The organization shall be able to provide a copy of the PII that is processed, when requested by the PII principal. 若个人身份信息（PII）主体请求时，组织应能够提供已被处理的个人身份信息（PII）的副本。
A.1.3.10	Handling requests 处理请求	The organization shall define and document policies and procedures for handling and responding to legitimate requests from PII principals. 组织应定义和文件化策略和规程，以处理和响应来自个人身份信息（PII）主体的正当请求。
A.1.3.11	Automated decision making 自动化决策	The organization shall identify and address obligations, including legal obligations, to the PII principals resulting from decisions made by the organization which are related to the PII principal based solely on automated processing of PII, and be able to demonstrate how it addresses these obligations. 组织应识别和处理由仅基于个人身份信息（PII）自动化处理的个人身份信息（PII）主体相关的组织所做决策产生的对个人身份信息（PII）主体的义务，包括法律义务，并且能够证明是如何处理这些义务的。
Privacy by design and privacy by default 隐私设计和隐私默认保护 **Objective 目标:** To ensure that processes and systems are designed such that the collection and processing of PII (including use, disclosure, retention, transmission and disposal) are limited to what is necessary for the identified purpose. 为确保流程和系统被设计，以至于个人身份信息（PII）的收集和处理（包含使用，披露，保存，传输和清除）仅被限于表明的目的所必要的范围之内。		
A.1.4.2	Limit collection 限制收集	The organization shall limit the collection of PII to the minimum that is relevant, proportional and necessary for the identified purposes. 组织应将个人身份信息（PII）的收集限制在适宜的，相称的以及表明的目的所必要的最低限度。
A.1.4.3	Limit processing 限制处理	The organization shall limit the processing of PII to that which is adequate, relevant and necessary for the identified purposes. 组织应将个人身份信息（PII）的处理限制在适当的，适宜的以及表明的目的所必要的程度。
A.1.4.4	Accuracy and quality 准确性和质量	The organization shall ensure and document that PII is as accurate, complete and up to date as is necessary for the purposes for which it is processed, throughout the life cycle of the PII. 在个人身份信息（PII）的整个生命周期中，

		组织应确保个人身份信息（PII）是准确的，完整的和最新的，以满足个人身份信息（PII）处理目的的需要，并文件化相关信息。
A.1.4.5	PII minimization objectives 个人身份信息（PII）的最小化目标	The organization shall define and document data minimization objectives and what mechanisms (such as de-identification) are used to meet those objectives. 组织应定义和文件化数据的最小化目标，以及使用何种机制（诸如去标识化）来实现这些目标。
A.1.4.6	PII de-identification and deletion at the end of processing 处理终止时的个人身份信息（PII）的去标识化和删除	The organization shall either delete PII or render it in a form which does not permit identification or re-identification of PII principals, as soon as the original PII is no longer necessary for the identified purpose(s). 只要表明的目的不再需要原始的个人身份信息（PII），组织应删除个人身份信息（PII），或使其成为不允许对个人身份信息（PII）进行标识或重新标识的格式。
A.1.4.7	Temporary files 临时文件	The organization shall ensure that temporary files created as a result of the processing of PII are disposed of (e.g. erased or destroyed) following documented procedures within a specified, documented period. 组织应确保因个人身份信息（PII）处理而产生的临时文件按照文件化的规程在规定的文件化的时间内被处置（例如，清除或销毁）。
A.1.4.8	Retention 保存	The organization shall not retain PII for longer than is necessary for the purposes for which the PII is processed. 组织保留个人身份信息（PII）的时间不应超过个人身份信息（PII）处理目的所需要的时间。
A.1.4.9	Disposal 处置	The organization shall have documented policies, procedures or mechanisms for the disposal of PII. 组织应为个人身份信息（PII）的处置制定文件化的策略，规程或机制。
A.1.4.10	PII transmission controls 个人身份信息（PII）传输的控制	The organization shall subject PII transmitted (e.g. sent to another organization) over a data-transmission network to appropriate controls designed to ensure that the data reaches its intended destination. 组织应使通过数据传输网络传输(例如，发送到另一个组织)的个人身份信息（PII）受到适当的控制，以确保数据到达其预期的目的地。
PII sharing, transfer and disclosure 个人身份信息（PII）的共享，转移和披露 **Objective 目标:** To determine whether and document when, PII is shared, transferred to other jurisdictions or third parties or disclosed in accordance with applicable obligations. 为确定个人身份信息（PII）是否被共享，以及何时被转移至其他司法管辖区或第三		

方，或依据适用的义务被披露，并文件化这些信息。		
A.1.5.2	Identify basis for PII transfer between jurisdictions 识别个人身份信息（PII）在司法管辖区之间转移的依据	The organization shall identify and document the relevant basis for transfers of PII between jurisdictions. 组织应为司法管辖区之间的个人身份信息（PII）的转移识别和文件化适用的依据。
A.1.5.3	Countries and international organizations to which PII can be transferred 个人身份信息（PII）可能转移到的国家和国际组织	The organization shall specify and document the countries and international organizations to which PII can possibly be transferred. 组织应明确和文件化个人身份信息（PII）可能被转移到的国家和国际组织。
A.1.5.4	Records of transfer of PII 个人身份信息（PII）转移的记录	The organization shall record transfers of PII to or from third parties and ensure cooperation with those parties to support future requests related to obligations to the PII principals. 组织应记录个人身份信息（PII）转移至第三方或从第三方转移出，并确保这些合作的当事方支持未来对个人身份信息（PII）主体相关的请求。
A.1.5.5	Records of PII disclosure to third parties 个人身份信息（PII）披露给第三方的记录	The organization shall record disclosures of PII to third parties, including which PII has been disclosed, to whom and at what time. 组织应记录个人身份信息（PII）对第三方的披露，包括披露了什么个人身份信息（PII），披露给了谁，以及在何时披露的。

Table A.2—Control objectives and controls for PII processors

表 2 个人身份信息处理者控制目标和控制项

Conditions for collection and processing 收集和处理条件 **Objective 目标:** To determine and document that processing is lawful, with legal basis as per applicable jurisdictions, and with clearly defined and legitimate purposes. 为确定和文件化处理是合法的，且符合各个适用的司法管辖区的法律依据，以及有清晰的定义和正当目的。		
Control Reference 控制索引	**Control title 控制标题**	**Control 控制**
A.2.2.2	Customer agreement 顾客协议	The organization shall ensure, where relevant, that the contract to process PII addresses the organization's role in providing assistance with the customer's obligations, (taking into account the nature of processing and the information available to the organization). 若适宜，组织应确保处理个人身份信息（PII）的合同明确对顾客的义务提供协助的组织角色（考虑处理的性质和组织可获得的信息）。
A.2.2.3	Organization's purposes 组织的目的	The organization shall ensure that PII processed on behalf of a customer are only processed for the purposes expressed in the documented instructions of the customer. 组织应确保代表顾客处理的个人身份信息（PII）仅因在顾客的文件化的说明中所表达的目的而被处理。
A.2.2.4	Marketing and advertising use 市场营销和广告用途	The organization shall not use PII processed under a contract for the purposes of marketing and advertising without establishing that prior consent was obtained from the appropriate PII principal. The organization shall not make providing such consent a condition for receiving the service. 在没有确定从个人身份信息（PII）主体获得了事先的许可时，组织不应因市场营销和广告目的而使用合同中处理的个人身份信息（PII）。组织不应让提供这类许可成为接受服务的条件。
A.2.2.5	Infringing instruction 违背指令	The organization shall inform the customer if, in its opinion, a processing instruction infringes applicable legal requirements.在组织看来，若处理指令违背适用的法律要求，组织应将此通知顾客。
A.2.2.6	Customer obligations 顾客义务	The organization shall provide the customer with the appropriate information such that the customer can demonstrate compliance with their obligations. 组织应向顾客提供适宜的信息，以便顾客可

		以证明对其义务的遵守。
A.2.2.7	Records related to processing PII 处理个人身份信息（PII）有关的记录	The organization shall determine and maintain the necessary records in support of demonstrating compliance with its obligations (as specified in the applicable contract) for the processing of PII carried out on behalf of a customer. 组织应确定和保持必要的记录，以便支持证明对其代表顾客实施个人身份信息（PII）处理的义务（按照适用的合同中的规定）的遵守。
Obligations to PII principals 对个人身份信息（PII）主体的义务 **Objective 目标:** To ensure that PII principals are provided with the appropriate information about the processing of their PII, and to meet any other applicable obligations to PII principals related to the processing of their PII. 为确保将个人身份信息（PII）主体的个人身份信息（PII）处理相关的适当信息提供给个人身份信息（PII）主体，以及为满足对个人身份信息（PII）主体的个人身份信息（PII）处理相关的个人身份信息（PII）主体的任何其他适当义务。		
A.2.3.2	Comply with obligations to PII principals 遵守对个人身份信息（PII）主体的义务	The organization shall provide the customer with the means to comply with its obligations related to PII principals. 组织应向顾客提供遵守其与个人身份信息（PII）主体相关义务的方法。
Privacy by design and privacy by default 隐私设计和隐私默认保护 **Objective 目标:** To ensure that processes and systems are designed such that the collection and processing of PII (including use, disclosure, retention, transmission and disposal) are limited to what is necessary for the identified purpose. 为确保流程和系统被设计，以至于个人身份信息（PII）的收集和处理（包含使用，披露，保存，传输和清除）仅被限于表明的目的所必要的范围之内。		
A.2.4.2	Temporary files 临时文件	The organization shall ensure that temporary files created as a result of the processing of PII are disposed of (e.g. erased or destroyed) following documented procedures within a specified, documented period. 组织应确保因个人身份信息（PII）处理而产生的临时文件按照文件化的规程在规定的文件化的时间内被处置（例如，清除或销毁）。
A.2.4.3	Return, transfer or disposal of PII 个人身份信息（PII）的归还，转移或处置	The organization shall be able to return, transfer or disposal of PII in a secure manner. It shall also make its policy available to the customer. 组织应能够以安全的方式归还，转移或处置个人身份信息。组织也应向顾客提供其策略。
A.2.4.4	PII transmission controls 个人身份信息（PII）传输的控制	The organization shall subject PII transmitted over a data-transmission network to appropriate controls, which are designed to ensure that the data reaches its intended destination. 组织应使通过数据传输网络传输的个人身份

		信息（PII）受到适当的控制，以确保数据到达其预期的目的地。
PII sharing, transfer and disclosure 个人身份信息的共享，转移和披露 **Objective 目标:** To determine whether and document when, PII is shared, transferred to other jurisdictions or third parties, or disclose according to applicable obligations. 为确定个人身份信息（PII）是否被共享，以及何时被转移至其他司法管辖区或第三方，或依据适用的义务被披露，并文件化这些信息。		
A.2.5.2	Basis for PII transfer between jurisdictions 个人身份信息（PII）在司法管辖区之间转移的依据	The organization shall inform the customer in a timely manner of the basis for PII transfers between jurisdictions and of any intended changes in this regard, so that the customer can object to such changes or to terminate the contract. 组织应采取及时的方式将个人身份信息（PII）在司法管辖区之间转移的依据和在这方面的所有预期的变更通知到顾客，以便顾客可以反对此类变更或终止合同。
A.2.5.3	Countries and international organizations to which PII can be transferred 个人身份信息（PII）可能转移到的国家和国际组织	The organization shall specify and document the countries and international organizations to which PII can possibly be transferred. 组织应明确和文件化个人身份信息（PII）可能被转移到的国家和国际组织。
A.2.5.4	Records of PII disclosure to third parties 个人身份信息（PII）披露给第三方的记录	The organization shall record disclosures of PII to third parties, including which PII has been disclosed, to whom and when. 组织应记录个人身份信息（PII）对第三方的披露，包括披露了什么个人身份信息（PII），披露给了谁，以及在何时披露的。
A.2.5.5	Notification of PII disclosure requests 个人身份信息（PII）披露请求的通知	The organization shall notify the customer of any legally binding requests for disclosure of PII. 组织应将所有具有法律约束力的个人身份信息（PII）披露的请求通知到顾客。
A.2.5.6	Legally binding PII disclosures 具有法律约束力的个人身份信息（PII）的披露	The organization shall reject any requests for PII disclosures that are not legally binding, consult the corresponding customer before making any PII disclosures and accept any contractually agreed requests for PII disclosures that are authorized by the corresponding customer. 组织应拒绝所有不具法律约束力的个人身份信息（PII）披露的请求，在做任何个人身份信息（PII）披露和接受相应顾客授权的任何合同约定的个人身份信息（PII）披露的请求之前，应向相应的顾客咨询。
A.2.5.7	Disclosure of subcontractors used to process PII 用于处理个人身份信息（PII）的分包商的披露	Before use, the organization shall disclose whether any subcontractors are used to process PII to the customer. 组织应在使用前向顾客披露是否有使用处理个人身份信息（PII）的分包商。
A.2.5.8	Engagement of a subcontractor to process	The organization shall only engage a subcontractor to process PII according to

	PII 处理个人身份信息（PII）的分包商的雇用	the customer contract. 组织应只根据顾客合同雇佣处理个人身份信息（PII）的分包商。
A.2.5.9	Change of subcontractor to process PII 处理个人身份信息（PII）的分包商的变更	The organization shall, in the case of having general written authorization, inform the customer of any intended changes concerning the addition or replacement of subcontractors to process PII, thereby giving the customer the opportunity to object to such changes. 在获得一般书面授权的情况下，组织应将任何预期的涉及处理个人身份信息（PII）分包商的增加或替代的变更通知到顾客，从而让顾客有机会反对此类变更。

Table A.3—Control objectives and controls for PII controllers and PII processors

表 A.3 个人身份信息控制者和个人身份信息处理者控制目标和控制项

Security considerations for PII controllers and processors 个人身份信息控制者和处理者安全考虑 **Objective 目标:** To ensure the security of PII processing. 确保个人身份信息处理的安全。		
Control Reference 控制索引	**Control title 控制标题**	**Control 控制**
A.3.3	Policies for information security 信息安全策略	Information security policies related to PII processing shall be defined, approved by management, published, communicated to and acknowledged by relevant personnel and relevant interested parties, and reviewed at planned intervals and if significant changes occur. 管理者应制定，批准和发布个人身份信息处理相关的信息安全策略，并将这些策略沟通到关联的人员和关联的相关方。按照策划的时间间隔，对这些策略进行评审，发生重大变化时，需要增加评审。
A.3.4	Information security roles and responsibilities 信息安全角色和职责	Information security roles and responsibilities related to PII processing shall be defined and allocated according to the organizational needs. 应根据组织需求定义和分配个人身份信息处理相关的信息安全角色和职责。
A.3.5	Classification of information 信息分级	Information shall be classified according to the information security needs of the organization, taking into consideration PII, based on confidentiality, integrity, availability and relevant interested party requirements. 应按照组织的信息安全需求，对信息进行分级。组织信息安全需求，可以由个人身份信息的保密性，完整性，可用性，及其关联的相关方确定。
A.3.6	Labelling of information 信息标记	An appropriate set of procedures for information labelling that considers PII shall be developed and implemented in accordance with the information classification scheme adopted by the organization. 根据组织采纳的信息分级方案，应编制和实施包含个人身份信息在内的适当信息标记规程
A.3.7	Information transfer	Information transfer rules, procedures, or

	信息传输	agreements related to processing PII shall be in place for all types of transfer facilities within the organization and between the organization and other parties. 应为组织内部以及组织与其他方之间的所有类型的传输设施制定个人身份信息处理关联的信息传输规则、规程或协议。
A.3.8	Identity management 身份管理	The full life cycle of identities related to PII processing shall be managed. 应管理个人身份信息处理关联身份的整个生命周期。
A.3.9	Access rights 访问权	Access rights to PII and other associated assets related to PII processing shall be provisioned, reviewed, modified and removed in accordance with the organization's topic-specific policy on and rules for access control. 应根据组织特定主题的访问控制策略和规则对个人身份信息和其他个人身份信息处理关联资产的访问权进行分配、评审、修改和删除。
A.3.10	Addressing information security within supplier agreements 在供应商协议中强调信息安全	Relevant information security requirements related to PII processing shall be established and agreed with each supplier based on the type of supplier relationship. 应基于供应商关系类型，建立相关与个人身份信息处理关联的信息安全要求，并与各供应商就这些信息安全要求达成一致。
A.3.11	Information security incident management planning and preparation 信息安全事件管理的策划和准备	The organization shall plan and prepare for managing information security incidents related to PII processing by defining, establishing and communicating incident management processes, roles and responsibilities. 组织应定义、建立和沟通个人身份信息处理关联的信息安全事件管理过程、角色和职责，以策划和准备信息安全事件的管理。
A.3.12	Response to information security incidents 信息安全事件的响应	Responses to information security incidents related to PII processing shall be according to the documented procedures. 组织应按照文件化的规程响应个人身份信息处理关联的信息安全事件。
A.3.13	Legal, statutory, regulatory and contractual requirements 法律、法规、规章和合同要求	Legal, statutory, regulatory and contractual requirements relevant to information security related to PII processing and the organization's approach to meet these requirements shall be documented and this documentation kept up to date. 应识别个人身份信息处理关联的信息安全相关的法律、法规、规章和合同要求，以及组织满足这些要求的方法，并形成文件和保持更新。
A.3.14	Protection of records 记录的保护	Records related to PII processing shall be protected from loss, destruction, falsification, unauthorized access and unauthorized release.

		个人身份信息处理关联的记录应进行保护以防其丢失、毁坏、伪造、未授权访问和未授权发布。
A.3.15	Independent review of information security 信息安全独立评审	The organization's approach to managing information security related to PII processing and its implementation including people, processes and technologies shall be reviewed independently at planned intervals, or when significant changes occur. 应按策划的时间间隔或在重大变化发生时，对组织个人身份信息处理关联的信息安全管理方法及其实施包括人员、过程和技术应进行独立评审。
A.3.16	Compliance with policies, rules and standards for information security 信息安全策略、规则和标准的符合性	Compliance with the organization's information security policy, topic-specific policies, rules and standards related to PII processing shall be regularly reviewed. 应定期评审组织个人身份信息处理关联的信息安全策略、特定主题的策略、规则和标准的符合性。
A.3.17	Information security awareness, education and training 信息安全意识、教育和培训	Personnel of the organization and relevant interested parties shall receive appropriate information security awareness education and training, and regular updates of the organization's information security policy, topic-specific policies and procedures, as relevant for their job function, as they relate to PII processing. 组织和相关方的员工，当其与个人身份信息处理关联时，应按其工作职能，接受适当的意识、教育和培训，以及定期更新的组织信息安全策略、特定主题策略及规程。
A.3.18	Confidentiality or non-disclosure agreements 保密或不泄露协议	Confidentiality or non-disclosure agreements reflecting the organization's needs for the protection of PII shall be identified, documented, regularly reviewed and signed by personnel and other relevant interested parties. 应识别、文件化和定期评审反映组织个人身份信息保护需要的保密性或不泄露协议，并由员工和其他相关方签署。
A.3.19	Clear desk and clear screen 清空桌面和屏幕	Clear desk rules for papers and removable storage media and clear screen rules for information processing facilities shall be defined and appropriately enforced. 针对纸质和可移动存储介质的清理桌面策略，以及针对信息处理设施的清理屏幕策略，应被定义和适当执行。
A.3.20	Storage media 存储介质	Storage media with PII shall be managed through its life cycle of acquisition, use, transportation and disposal in accordance with the organization's classification scheme and handing requirements. 含有个人身份信息的存储介质应按照组织的分类方案和处理要求，对其获取、使用、运输和处置的生命周期进行管理。

A.3.21	Secure disposal or re-use of equipment 设备的安全处置或再利用	Items of equipment containing storage media with PII shall be verified to ensure that any sensitive data and licensed software has been removed or securely overwritten prior to disposal or re-use. 配有含有个人身份信息储存介质的设备项目应进行核查，以确保在处置或再利用之前，任何敏感信息和注册软件已被删除或安全的重写。
A.3.22	User endpoint devices 用户终端设备	PII stored on, processed by or accessible via user endpoint devices shall be protected. 存储在、由用户终端设备处理或通过用户终端设备访问的个人身份信息应受到保护。
A.3.23	Secure authentication 安全鉴别	Secure authentication technologies and procedures related to PII processing shall be implemented based on information access restrictions. 应基于信息安全访问限，实施个人身份信息处理关联的安全鉴别技术和规程。
A.3.24	Information backup 信息备份	Backup copies of PII, and software and systems related to PII processing shall be maintained and regularly tested. 应对个人身份信息的备份副本，以及个人身份信息处理关联的软件和系统进行维护，并定期进行测试。
A.3.25	Logging 日志	Logs that record activities, exceptions, faults and other relevant events related to PII processing shall be produced, stored, protected and analysed. 记录个人身份信息处理关联活动、异常、故障和其他相关事件的日志应产生、存储、保护和分析。
A.3.26	Use of cryptography 密码学的使用	Rules for the effective use of cryptography related to PII processing, including cryptographic key management, shall be defined and implemented. 个人身份信息处理关联的有效使用密码学的规则，包括密钥的管理，应被定义，并予以实施。
A.3.27	Secure development life cycle 安全的开发生命周期	Rules for the secure development of software and systems related to PII processing shall be established and applied. 个人身份信息处理关联的软件和系统的安全开发规则应被建立，并予以应用。
A.3.28	Application security requirements 应用安全要求	Information security requirements related to PII processing shall be identified, specified and approved when developing or acquiring applications. 当开发或获取应用时，个人身份信息处理关联的信息安全要求应被识别、规定和批准。
A.3.29	Secure system architecture and engineering principles 安全系统架构和工程原则	Principles for engineering secure systems related to processing PII shall be established, documented, maintained and applied to any information system development activities. 应建立和维护文件化的个人身份信息处理关联的工程安全系统原则，并应用于任何的信

		息系统开发活动。
A.3.30	Outsourced development 开发外包	The organization shall direct, monitor and review the activities related to outsourced PII processing system development. 组织应指导、监视和评审外包的个人身份信息处理系统开发的相关活动。
A.3.31	Test information 测试信息	Test information related to PII processing shall be appropriately selected, protected and managed. 个人身份信息处理关联的测试信息应被适当筛选、保护和管理。

Annex B 附录 B

Implementation guidance for PII controllers and PII processors

个人身份信息控制者和个人身份信息处理者实施指南

<由于建立和实施隐私信息管理体系时，附录 B 是非必要的内容，只是参考内容，故本文件将附录 B 省略，如有需要阅览，可以前往以下链接下载英文原本标准>

https://bbs.27001.cn/233-1-1.shtml

Annex C 附录 C

Mapping to ISO/IEC 29100

对 ISO/IEC 29100 的映射

<由于建立和实施隐私信息管理体系时，附录 C 是非必要的内容，只是参考内容，故本文件将附录 C 省略，如有需要阅览，可以前往以下链接下载英文原本标准>

https://bbs.27001.cn/233-1-1.shtml

Annex D 附录 D

Mapping to the General Data Protection Regulation

对通用数据保护条例（GDPR）的映射

<由于建立和实施隐私信息管理体系时，附录 D 是非必要的内容，只是参考内容，故本文件将附录 D 省略，如有需要阅览，可以前往以下链接下载英文原本标准>

https://bbs.27001.cn/233-1-1.shtml

Annex E 附录 E

Mapping to ISO/IEC27018 and ISO/IEC29151

对 ISO/IEC27018 和 ISO/IEC29151 的映射

<由于建立和实施隐私信息管理体系时，附录 E 是非必要的内容，只是参考内容，故本文件将附录 E 省略，如有需要阅览，可以前往以下链接下载英文原本标准>

https://bbs.27001.cn/233-1-1.shtml

Annex F 附录 F

Correspondence with ISO/IEC 27701:2019

与 ISO/IEC 27701:2019 的关联

<由于建立和实施隐私信息管理体系时，附录 F 是非必要的内容，只是参考内容，故本文件将附录 F 省略，如有需要阅览，可以前往以下链接下载英文原本标准>

https://bbs.27001.cn/233-1-1.shtml